

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Outlining a new SiestaGraph backdoor

Date of Publication

December 20, 2022

Admiralty Code

A1

TA Number

TA2022306

Summary

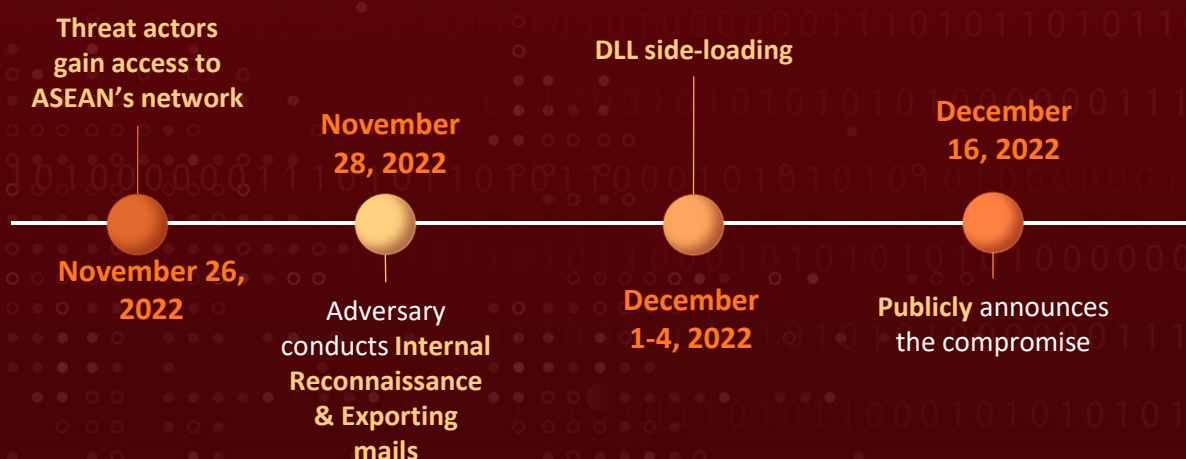
First appeared: October 14, 2022

Attack Region: Brunei, Myanmar, Cambodia, Timor-Leste, Indonesia, Laos, Malaysia, Philippines, Singapore, Thailand, Vietnam

Attack Industries: Foreign ministry

Attack: The threat actor prioritized diplomatic intelligence gathering via the SiestaGraph backdoor, which leverages the Microsoft Graph API.

Attack Timeline



Attack Regions



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Attack Details

#1

The Foreign Affairs Office of an Association of Southeast Asian Nations (ASEAN) member is targeted by multiple threat actors who are coordinating active campaigns via a vulnerable Microsoft Exchange server. Upon establishing access, the victim's emails are exported. The attack chain begins with the execution of "SiestaGraph," which is named for the long sleep timer and the way the backdoor leverages the Microsoft Graph API for command and control.

#2

SiestaGraph tends to make use of a .NET API package that can be used conversely of Microsoft Graph API. Following the initial access, the threat actor gathers domain user and group information before exporting and archiving victim mailboxes as PST files. A customized version of an IIS backdoor called DoorMe with enhanced capability was used to allocate shellcode and load further implants.

Recommendations



Security Leaders

Phishing simulations and routine education and awareness training and communications rarely account for MFA fatigue and web browser hygiene. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize and block all indicators attributed to the threat actors and attacks through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Indicators of Compromise (IoC)' on the following pages.

Potential MITRE ATT&CK TTPs

<u>TA0043</u> Reconnaissance	<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0003</u> Persistence
<u>TA0005</u> Defense Evasion	<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0008</u> Lateral Movement
<u>TA0009</u> Collection	<u>TA0011</u> Command and Control	<u>T1592</u> Gather Victim Host Information	<u>T1589</u> Gather Victim Identity Information
<u>T1590</u> Gather Victim Network Information	<u>T1591</u> Gather Victim Org Information	<u>T1591.004</u> Identify Roles	<u>T1190</u> Exploit Public-Facing Application
<u>T1059</u> Command and Scripting Interpreter	<u>T1059.001</u> PowerShell	<u>T1059.003</u> Windows Command Shell	<u>T1135</u> Network Share Discovery
<u>T1018</u> Remote System Discovery	<u>T1083</u> File and Directory Discovery	<u>T1057</u> Process Discovery	<u>T1021</u> Remote Services
<u>T1021.002</u> SMB/Windows Admin Shares	<u>T1007</u> System Service Discovery	<u>T1033</u> System Owner/User Discovery	<u>T1574</u> Hijack Execution Flow
<u>T1574.002</u> DLL Side-Loading	<u>T1036</u> Masquerading	<u>T1036.004</u> Masquerade Task or Service	<u>T1055</u> Process Injection
<u>T1070</u> Indicator Removal	<u>T1070.004</u> File Deletion	<u>T1140</u> Deobfuscate/Decode Files or Information	<u>T1497</u> Virtualization/Sandbox Evasion
<u>T1497.003</u> Time Based Evasion	<u>T1003</u> OS Credential Dumping	<u>T1003.003</u> NTDS	<u>T1003.002</u> Security Account Manager
<u>T1003.006</u> DCSync	<u>T1543</u> Create or Modify System Process	<u>T1543.003</u> Windows Service	<u>T1053</u> Scheduled Task/Job
<u>T1053.005</u> Scheduled Task	<u>T1078</u> Valid Accounts	<u>T1505</u> Server Software Component	<u>T1505.004</u> IIS Components
<u>T1505.003</u> Web Shell	<u>T1114</u> Email Collection	<u>T1114.001</u> Local Email Collection	<u>T1560</u> Archive Collected Data
<u>T1560.001</u> Archive via Utility	<u>T1113</u> Screen Capture	<u>T1102</u> Web Service	<u>T1071</u> Application Layer Protocol
<u>T1071.001</u> Web Protocols			

✂ Indicator of Compromise (IOCs)

TYPE	VALUE
SHA256	1a87e1b41341ad042711faa0c601e7b238a47fa647c325f66b1c8c7b313c8bdf7fc54a287c08cde70fe860f7c65ff71ade24dfeedafdf6a62a8a6ee57cc91950f9b2b3f7ee55014cc8ad696263b24a21ebd3a043ed1255ac4ab6a63ad4851094c283ceb230c6796d8c4d180d51f30e764ec82cfca0dfaa80ee17bb4fdf89c3e04b7d244883c762c52a0632b186562ece7324881a8e593418262243a5d86a274d54f969ce5c4be11df293db600df57debcb0bf27ecad38ba60d0e44d4439c39b6509628b6d16d2428031311d7bd2add8d5f5160e9ecc0cd909f1e82bbbbb3234d6386eb7aa33c76ce671d6685f79512597f1fab28ea46c8ec7d89e58340081e2bd452b08d6d2aa673fb6ccc4af6cebdcb12b5df8722f4d70d1c3491479e7b39c055be0045a2c86c38714ada4084080210ced8bc5b6865aef1cca658b263ff696dc3f5377590689bd19c8dd0a9d46f30856c90d4ee1c03a68385973188b44cc9ab7f2a9ee6dd4d1ceb4d97138755c919549549311c06859f236fc8655cf38fe56533b41c46824b78263d11b1c8d39cfe8c0e140f27c20612d954b133ffb110d206a9b66cd1a80727882cfa1303ada37019086c882c9543b3f957ee3906440dc8276
IP Address	185.239.70[.]229

✂ Recent Breaches

<https://asean.org/what-we-do>

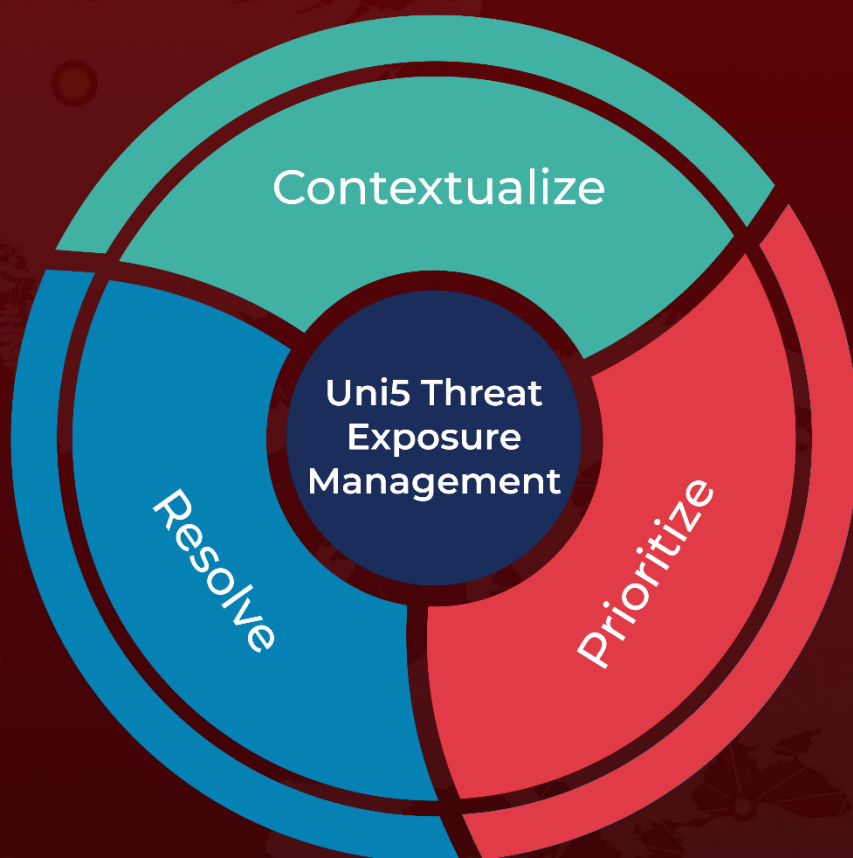
✂ References

<https://www.elastic.co/security-labs/siestagraph-new-implant-uncovered-in-asean-member-foreign-ministry>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 20, 2022 • 5:15 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com